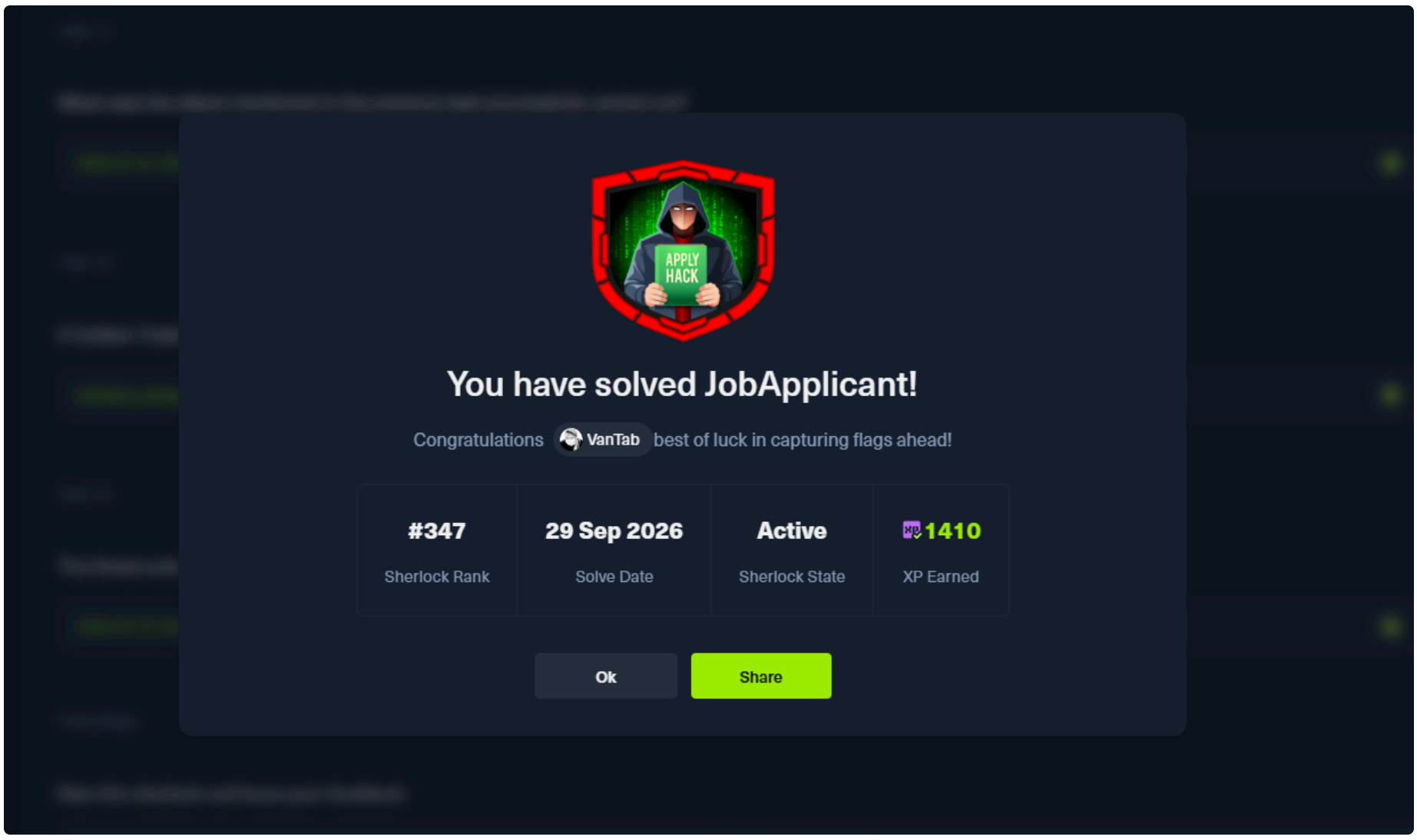
JobApplicant writ3up

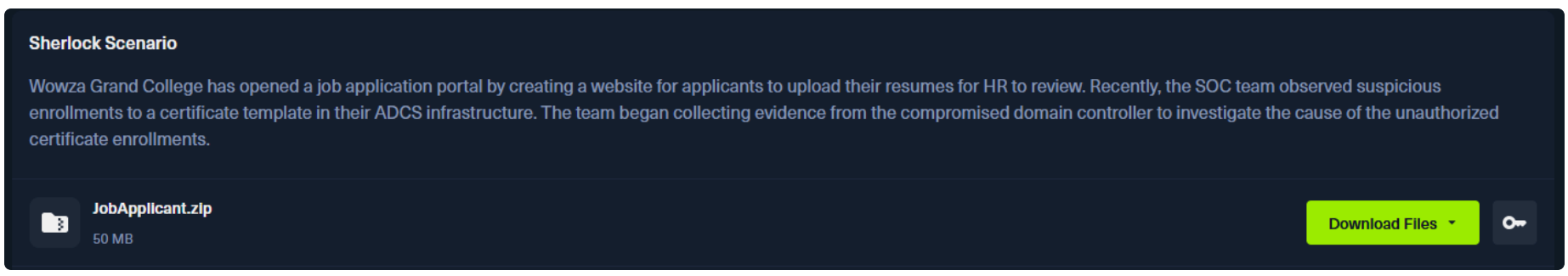


JobApplicant

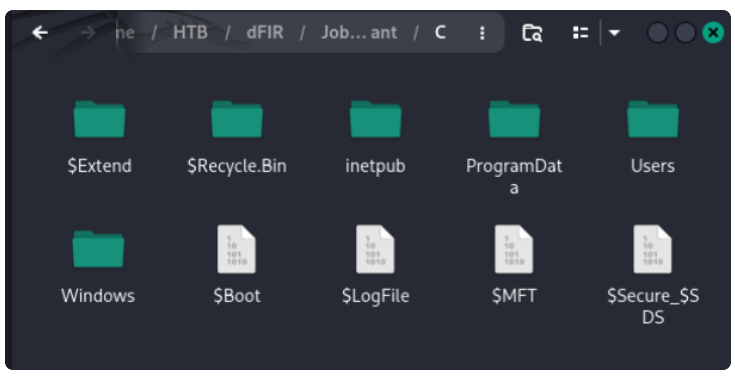
https://app.hackthebox.com/sherlocks/JobApplicant?tab=play_sherlock

---

The first need to download the file



so after that i try to discover what i have inside?
and its look like C Windows folder



file/folder	What it contains	How it helps in my invest
`$MFT`	NTFS records for files and directories, including names, paths, timestamp, size, and metadata.	Helps reconstruct **file activity**, identify deleted files, and build a filesystem timeline.
`$LogFile`	NTFS transaction records related to filesystem metadata changes.	Helps identify and reconstruct **recent filesystem operations** such as creation, deletion, renaming, and modification.
`$Extend`	Additional NTFS metadata, including the USN Journal `$UsnJrnl` & `$J`.	Useful for tracking filesystem changes and determining when files were created, modified, renamed, or deleted.
`$Recycle.Bin`	Deleted files and metadata such as original paths and deletion times.	Helps determine what the user deleted, when it was deleted, and where it originally existed.

file/folder	What it contains	How it helps in my invest
`Users`	User profiles, Desktop, Downloads, Documents, AppData, browser data, `NTUSER.DAT`, etc.	Helps investigate **user activity**, downloaded files, browsing, application usage, and user specific configuration.
`Windows`	OS files, Registry hives, Event Logs, Prefetch, system configuration, and other Windows artifacts.	One of the main sources for investigating logons, process execution, services, system changes, errors, and security events.
`inetpub`	IIS website files and potentially IIS access logs.	Important in web server log search for identify **HTTP requests, source IPs, requested URLs, status codes, and suspicious web activity**.
`ProgramData`	Application wide configuration, logs, caches, security tool data, and other shared program data.	Can reveal application activity, security product logs, persistence artifacts, and configuration changes.
`$Boot`	NTFS boot sector information and filesystem parameters.	useful for **filesystem/volume analysis** rather than normal user activity investigations.
`$Secure:$SDS`	NTFS security descriptors, including permissions and ownership information.	useful for investigating file permissions, ownership, and access control changes.

the interest folder here is `inepub` *"the inetpub folder is a directory created by Microsoft as part of the Internet Information Services (IIS) used for hosting websites and web applications."*
So i can see here the record details about web server activity, including requests made to the server, response statuses, and the amount of data transferred.

after search on these folder i found a logs file inside `inepub` folder
and inside inside inside it finally found :

```
┌──(khaledd㉿VanTab)-[~/…/inetpub/logs/LogFiles/W3SVC1]
└─$ ls
u_ex250723.log  u_ex250724.log  u_ex250726.log  u_ex250727.log
```

lets see what contain ??

```
┌──(khaledd㉿VanTab)-[~/…/inetpub/logs/LogFiles/W3SVC1]
└─$ cat u_ex250723.log
#Software: Microsoft Internet Information Services 10.0
#Version: 1.0
#Date: 2025-07-23 14:43:35
#Fields: date time s-ip cs-method cs-uri-stem cs-uri-query s-port cs-username c-i
p cs(User-Agent) cs(Referer) sc-status sc-substatus sc-win32-status time-taken
2025-07-23 14:43:35 127.0.0.1 GET / - 80 - 127.0.0.1 Mozilla/5.0+(Windows+NT+10.0
;+Win64;+x64)+AppleWebKit/537.36+(KHTML,+like+Gecko)+Chrome/138.0.0.0+Safari/537.
36+Edg/138.0.0.0 - 200 0 0 1013
2025-07-23 14:43:35 127.0.0.1 GET /iisstart.png - 80 - 127.0.0.1 Mozilla/5.0+(Win
dows+NT+10.0;+Win64;+x64)+AppleWebKit/537.36+(KHTML,+like+Gecko)+Chrome/138.0.0.0
+Safari/537.36+Edg/138.0.0.0 http://resumeupload.wowza.edu/ 200 0 0 33
2025-07-23 14:43:35 127.0.0.1 GET /favicon.ico - 80 - 127.0.0.1 Mozilla/5.0+(Wind
ows+NT+10.0;+Win64;+x64)+AppleWebKit/537.36+(KHTML,+like+Gecko)+Chrome/138.0.0.0+
Safari/537.36+Edg/138.0.0.0 http://resumeupload.wowza.edu/ 404 0 2 4
2025-07-23 14:57:55 127.0.0.1 GET /default.aspx - 80 - 127.0.0.1 Mozilla/5.0+(Win
dows+NT+10.0;+Win64;+x64)+AppleWebKit/537.36+(KHTML,+like+Gecko)+Chrome/138.0.0.0
+Safari/537.36+Edg/138.0.0.0 - 200 0 0 2928
```

the first one not interest

```
┌──(khaledd㉿VanTab)-[~/…/inetpub/logs/LogFiles/W3SVC1]
└─$ head -n 30 u_ex250724.log
#Software: Microsoft Internet Information Services 10.0
#Version: 1.0
#Date: 2025-07-24 13:06:39
#Fields: date time s-ip cs-method cs-uri-stem cs-uri-query s-port cs-username c-i
p cs(User-Agent) cs(Referer) sc-status sc-substatus sc-win32-status time-taken
2025-07-24 13:06:39 127.0.0.1 GET /default.aspx - 80 - 127.0.0.1 Mozilla/5.0+(Win
dows+NT+10.0;+Win64;+x64)+AppleWebKit/537.36+(KHTML,+like+Gecko)+Chrome/138.0.0.0
+Safari/537.36+Edg/138.0.0.0 - 200 0 0 6893
2025-07-24 13:07:03 127.0.0.1 GET /favicon.ico - 80 - 127.0.0.1 Mozilla/5.0+(Wind
ows+NT+10.0;+Win64;+x64)+AppleWebKit/537.36+(KHTML,+like+Gecko)+Chrome/138.0.0.0+
Safari/537.36+Edg/138.0.0.0 http://resumeupload.wowza.edu/default.aspx 404 0 2 67
#Software: Microsoft Internet Information Services 10.0
#Version: 1.0
#Date: 2025-07-24 13:25:20
#Fields: date time s-ip cs-method cs-uri-stem cs-uri-query s-port cs-username c-i
p cs(User-Agent) cs(Referer) sc-status sc-substatus sc-win32-status time-taken
```

the second also

```
┌──(khaledd㉿VanTab)-[~/…/inetpub/logs/LogFiles/W3SVC1]
└─$ head -n 30 u_ex250726.log
#Software: Microsoft Internet Information Services 10.0
#Version: 1.0
#Date: 2025-07-26 03:39:42
#Fields: date time s-ip cs-method cs-uri-stem cs-uri-query s-port cs-username c-i
p cs(User-Agent) cs(Referer) sc-status sc-substatus sc-win32-status time-taken
2025-07-26 03:39:42 192.168.189.150 GET / - 80 - 192.168.189.75 Mozilla/5.0+(Wind
ows+NT+10.0;+Win64;+x64)+AppleWebKit/537.36+(KHTML,+like+Gecko)+Chrome/138.0.0.0+
Safari/537.36 - 200 0 0 6629
2025-07-26 03:39:44 192.168.189.150 GET /favicon.ico - 80 - 192.168.189.75 Mozill
a/5.0+(Windows+NT+10.0;+Win64;+x64)+AppleWebKit/537.36+(KHTML,+like+Gecko)+Chrome
/138.0.0.0+Safari/537.36 http://resumeupload.wowza.edu/ 404 0 2 112
2025-07-26 03:40:16 192.168.189.150 POST / - 80 - 192.168.189.75 Mozilla/5.0+(Win
dows+NT+10.0;+Win64;+x64)+AppleWebKit/537.36+(KHTML,+like+Gecko)+Chrome/138.0.0.0
+Safari/537.36 http://resumeupload.wowza.edu/ 200 0 0 571
#Software: Microsoft Internet Information Services 10.0
#Version: 1.0
#Date: 2025-07-26 05:41:24
#Fields: date time s-ip cs-method cs-uri-stem cs-uri-query s-port cs-username c-i
p cs(User-Agent) cs(Referer) sc-status sc-substatus sc-win32-status time-taken
2025-07-26 05:41:24 192.168.189.150 POST / - 80 - 192.168.189.75 Mozilla/5.0+(Win
dows+NT+10.0;+Win64;+x64)+AppleWebKit/537.36+(KHTML,+like+Gecko)+Chrome/138.0.0.0
```

the third nothing new

```
dows+NT+10.0;+Win64;+x64)+AppleWebKit/537.36+(KHTML,+like+Gecko)+Chrome/138.0.0.0
+Safari/537.36 http://resumeupload.wowza.edu/ 200 0 0 85
#Software: Microsoft Internet Information Services 10.0
#Version: 1.0
#Date: 2025-07-27 19:27:35
#Fields: date time s-ip cs-method cs-uri-stem cs-uri-query s-port cs-username c-i
p cs(User-Agent) cs(Referer) sc-status sc-substatus sc-win32-status time-taken
2025-07-27 19:27:35 192.168.189.150 GET /index.aspx - 80 - 143.198.231.177 Mozill
a/5.0+(X11;+Linux+x86_64;+rv:128.0)+Gecko/20100101+Firefox/128.0 - 404 0 0 737
2025-07-27 19:27:42 192.168.189.150 GET /main.aspx - 80 - 143.198.231.177 Mozilla
/5.0+(X11;+Linux+x86_64;+rv:128.0)+Gecko/20100101+Firefox/128.0 - 404 0 0 4
2025-07-27 19:27:51 192.168.189.150 GET /default.aspx - 80 - 143.198.231.177 Mozi
lla/5.0+(X11;+Linux+x86_64;+rv:128.0)+Gecko/20100101+Firefox/128.0 - 200 0 0 57
2025-07-27 19:28:18 192.168.189.150 POST /default.aspx - 80 - 143.198.231.177 Moz
illa/5.0+(X11;+Linux+x86_64;+rv:128.0)+Gecko/20100101+Firefox/128.0 http://resume
upload.wowza.edu/default.aspx 200 0 0 180
2025-07-27 19:28:29 192.168.189.150 POST /default.aspx - 80 - 143.198.231.177 Moz
illa/5.0+(X11;+Linux+x86_64;+rv:128.0)+Gecko/20100101+Firefox/128.0 http://resume
upload.wowza.edu/default.aspx 200 0 0 9
2025-07-27 19:28:50 192.168.189.150 GET /uploads - 80 - 143.198.231.177 Mozilla/5
.0+(X11;+Linux+x86_64;+rv:128.0)+Gecko/20100101+Firefox/128.0 - 404 0 2 4
2025-07-27 19:28:57 192.168.189.150 GET / - 80 - 143.198.231.177 feroxbuster/2.11
.0 - 200 0 0 58
```

but the fourth have a suspicious pattern ! lets see more its look like Web probing/endpoint discovery and then see to the usage `feroxbuster` for enumeration.



an open source tool uses brute force combined with a wordlist to search for unlinked content in target directories. These resources may store sensitive information about web applications and operational systems, such as source code, credentials, internal network addressing, etc...

~Q1 When did the threat actor first interact with the College's IT Infrastructure?
`2025-07-27 19:27:35`

~Q2 What is the malicious IP address used for initial reconnaissance and discovery?
`143.198.231.177`

and after the enumerate of attacker, he uplound this file `Resume9_eba15ba0-81ca-4d0f-9fad-3fc1fc92c181.pdf`

```
┌──(khaledd㉿VanTab)-[~/…/inetpub/logs/LogFiles/W3SVC1]
└─$ cat u_ex250727.log | grep "POST"
2025-07-27 17:40:07 192.168.189.150 POST / - 80 - 192.168.189.75 Mozilla/5.0+(Windows+NT+10.0;+Win64;+x64)+AppleWebKit
/537.36+(KHTML,+like+Gecko)+Chrome/138.0.0.0+Safari/537.36 http://resumeupload.wowza.edu/ 200 0 0 51
2025-07-27 17:49:46 192.168.189.150 POST / - 80 - 192.168.189.75 Mozilla/5.0+(Windows+NT+10.0;+Win64;+x64)+AppleWebKit
/537.36+(KHTML,+like+Gecko)+Chrome/138.0.0.0+Safari/537.36 http://resumeupload.wowza.edu/ 200 0 0 85
2025-07-27 19:28:18 192.168.189.150 POST /default.aspx - 80 - 143.198.231.177 Mozilla/5.0+(X11;+Linux+x86_64;+rv:128.0
)+Gecko/20100101+Firefox/128.0 http://resumeupload.wowza.edu/default.aspx 200 0 0 180
2025-07-27 19:28:29 192.168.189.150 POST /default.aspx - 80 - 143.198.231.177 Mozilla/5.0+(X11;+Linux+x86_64;+rv:128.0
)+Gecko/20100101+Firefox/128.0 http://resumeupload.wowza.edu/default.aspx 200 0 0 9
2025-07-27 19:32:28 192.168.189.150 POST /default.aspx - 80 - 143.198.231.177 Mozilla/5.0+(X11;+Linux+x86_64;+rv:128.0
)+Gecko/20100101+Firefox/128.0 http://resumeupload.wowza.edu/default.aspx 200 0 0 5
2025-07-27 19:33:41 192.168.189.150 POST /resumes/Resume9_eba15ba0-81ca-4d0f-9fad-3fc1fc92c181.pdf fdir=C%3a%2f%2fUser
s 80 - 143.198.231.177 Mozilla/5.0+(X11;+Linux+x86_64;+rv:128.0)+Gecko/20100101+Firefox/128.0 http://resumeupload.wowz
a.edu/resumes/Resume9_eba15ba0-81ca-4d0f-9fad-3fc1fc92c181.pdf?fdir=C%3a%2f%2fUsers 200 0 0 916
2025-07-27 19:35:58 192.168.189.150 POST /resumes/Resume9_eba15ba0-81ca-4d0f-9fad-3fc1fc92c181.pdf - 80 - 143.198.231.
177 Mozilla/5.0+(X11;+Linux+x86_64;+rv:128.0)+Gecko/20100101+Firefox/128.0 http://resumeupload.wowza.edu/resumes/Resum
e9_eba15ba0-81ca-4d0f-9fad-3fc1fc92c181.pdf 200 0 0 12
2025-07-27 20:10:46 192.168.189.150 POST /resumes/Resume9_eba15ba0-81ca-4d0f-9fad-3fc1fc92c181.pdf - 80 - 143.198.231.
177 Mozilla/5.0+(X11;+Linux+x86_64;+rv:128.0)+Gecko/20100101+Firefox/128.0 http://resumeupload.wowza.edu/resumes/Resum
e9_eba15ba0-81ca-4d0f-9fad-3fc1fc92c181.pdf 200 0 0 2081179
```

~Q3 The threat actor uploaded a file using the file upload functionality. Under what name did the server store the uploaded resume file?
`Resume9_eba15ba0-81ca-4d0f-9fad-3fc1fc92c181.pdf`

but what after upload this file! the attacker start interact with the PDF endpoint using the `fdir` parameter to access different directories on the server.

```
 11770  2025-07-27 19:33:17 192.168.189.150 GET /resumes/Resume9_eba15ba0-81ca-4d0f-9fad-3fc1fc92c181.pdf fdir=C%3a%2finetpub%2fwwwroot%2f 80 - 143.198.231.177 Mozill
a/5.0+(X11;+Linux+x86_64;+rv:128.0)+Gecko/20100101+Firefox/128.0 http://resumeupload.wowza.edu/resumes/Resume9_eba15ba0-81ca-4d0f-9fad-3fc1fc92c181.pdf 200 0 0 5
 11771  2025-07-27 19:33:23 192.168.189.150 GET /resumes/Resume9_eba15ba0-81ca-4d0f-9fad-3fc1fc92c181.pdf fdir=C%3a%2f 80 - 143.198.231.177 Mozilla/5.0+(X11;+Linux+x8
6_64;+rv:128.0)+Gecko/20100101+Firefox/128.0 http://resumeupload.wowza.edu/resumes/Resume9_eba15ba0-81ca-4d0f-9fad-3fc1fc92c181.pdf?fdir=C%3a%2finetpub%2fwwwroot%2f 2
00 0 0 4
 11772  2025-07-27 19:33:28 192.168.189.150 GET /resumes/Resume9_eba15ba0-81ca-4d0f-9fad-3fc1fc92c181.pdf fdir=C%3a%2f%2fUsers 80 - 143.198.231.177 Mozilla/5.0+(X11;+
Linux+x86_64;+rv:128.0)+Gecko/20100101+Firefox/128.0 http://resumeupload.wowza.edu/resumes/Resume9_eba15ba0-81ca-4d0f-9fad-3fc1fc92c181.pdf?fdir=C%3a%2f 200 0 0 5
 11773  2025-07-27 19:33:41 192.168.189.150 POST /resumes/Resume9_eba15ba0-81ca-4d0f-9fad-3fc1fc92c181.pdf fdir=C%3a%2f%2fUsers 80 - 143.198.231.177 Mozilla/5.0+(X11;
+Linux+x86_64;+rv:128.0)+Gecko/20100101+Firefox/128.0 http://resumeupload.wowza.edu/resumes/Resume9_eba15ba0-81ca-4d0f-9fad-3fc1fc92c181.pdf?fdir=C%3a%2f%2fUsers 200
0 0 916
 11774  2025-07-27 19:33:49 192.168.189.150 GET /resumes/Resume9_eba15ba0-81ca-4d0f-9fad-3fc1fc92c181.pdf fdir=C%3a%2f 80 - 143.198.231.177 Mozilla/5.0+(X11;+Linux+x8
6_64;+rv:128.0)+Gecko/20100101+Firefox/128.0 http://resumeupload.wowza.edu/resumes/Resume9_eba15ba0-81ca-4d0f-9fad-3fc1fc92c181.pdf?fdir=C%3a%2f%2fUsers 200 0 0 2
 11775  2025-07-27 19:33:55 192.168.189.150 GET /resumes/Resume9_eba15ba0-81ca-4d0f-9fad-3fc1fc92c181.pdf fdir=C%3a%2f%2fShares 80 - 143.198.231.177 Mozilla/5.0+(X11;
+Linux+x86_64;+rv:128.0)+Gecko/20100101+Firefox/128.0 http://resumeupload.wowza.edu/resumes/Resume9_eba15ba0-81ca-4d0f-9fad-3fc1fc92c181.pdf?fdir=C%3a%2f 200 0 0 3
 11776  2025-07-27 19:34:02 192.168.189.150 GET /resumes/Resume9_eba15ba0-81ca-4d0f-9fad-3fc1fc92c181.pdf fdir=C%3a%2fShares%2f%2fResumeReview 80 - 143.198.231.177 Mo
zilla/5.0+(X11;+Linux+x86_64;+rv:128.0)+Gecko/20100101+Firefox/128.0 http://resumeupload.wowza.edu/resumes/Resume9_eba15ba0-81ca-4d0f-9fad-3fc1fc92c181.pdf?fdir=C%3a%
2f%2fShares 200 0 0 5
 11777  2025-07-27 19:34:23 192.168.189.150 GET /resumes/Resume9_eba15ba0-81ca-4d0f-9fad-3fc1fc92c181.pdf get=C%3a%2fShares%2fResumeReview%2f%2fCertificate_for_sign.c
er 80 - 143.198.231.177 Mozilla/5.0+(X11;+Linux+x86_64;+rv:128.0)+Gecko/20100101+Firefox/128.0 http://resumeupload.wowza.edu/resumes/Resume9_eba15ba0-81ca-4d0f-9fad-3
fc1fc92c181.pdf?fdir=C%3a%2fShares%2f%2fResumeReview 200 0 0 24
```

The attacker then use the `get` parameter to retrieve files outside the intended resume location:

```
get=C%3a%2fShares%2fResumeReview%2f%2fCertificate_for_sign.cer
get=C:\Shares\ResumeReview\ideal candidates.txt
```

This take us to that the uploaded PDF endpoint was being processed by a server side handler capable of using the supplied parameters to access files on the server. Rather than simply serving only the PDF as a static document, the endpoint was being abused to perform arbitrary file access.

```
2025-07-27 19:32:28.890783,web.config,ARCHIVE,DATA_TRUNCATION
2025-07-27 19:32:28.890783,web.config,ARCHIVE,DATA_EXTEND DATA_TRUNCATION
2025-07-27 19:32:28.890783,web.config,ARCHIVE,DATA_EXTEND DATA_TRUNCATION CLOSE
2025-07-27 20:35:55.558432,web.config.lnk,ARCHIVE,FILE_CREATE
2025-07-27 20:35:55.558432,web.config.lnk,ARCHIVE,DATA_EXTEND FILE_CREATE
2025-07-27 20:35:55.558432,web.config.lnk,ARCHIVE,DATA_OVERWRITE DATA_EXTEND FILE_CREATE
2025-07-27 20:35:55.558432,web.config.lnk,ARCHIVE,DATA_OVERWRITE DATA_EXTEND DATA_TRUNCATION FILE_CREATE
2025-07-27 20:35:55.558432,web.config.lnk,ARCHIVE,DATA_OVERWRITE DATA_EXTEND DATA_TRUNCATION FILE_CREATE BASIC_INFO_CHANGE
2025-07-27 20:35:55.558432,web.config.lnk,ARCHIVE,DATA_OVERWRITE DATA_EXTEND DATA_TRUNCATION FILE_CREATE BASIC_INFO_CHANGE CLOSE
2025-07-27 20:35:55.558432,web.config.lnk,ARCHIVE,BASIC_INFO_CHANGE
2025-07-27 20:35:55.558432,web.config.lnk,ARCHIVE,BASIC_INFO_CHANGE CLOSE
2025-07-27 20:35:55.558432,web.config.lnk,ARCHIVE,BASIC_INFO_CHANGE
2025-07-27 20:35:55.558432,web.config.lnk,ARCHIVE,BASIC_INFO_CHANGE CLOSE
```

This is consistent with the use of a malicious `web.config` file, in IIS/ASP.NET, `web.config` can modify how file extensions are handled and can map a `.pdf` extension to an ASP.NET handler. This would cause requests to the PDF to be processed by the application rather than being treated as a normal static PDF file.

~Q4 The threat actor uploaded another file in order to change the behavior of this website, allowing the first uploaded file to act as a webshell. What is the name of the uploaded file?
`web.config`

So when see the the another activity of attacker after upload the PDF file, can see clearly the `del` parameter used during the cleaning activity
`del=C%3a%2finetpub%2fwwwroot%2fresumes%2f%2f8619.exe`

```
me/136.0.0.0+Safari/537.36+Edg/136.0.3240.50 - 404 0 2 2
 11792  2025-07-27 20:10:46 192.168.189.150 POST /resumes/Resume9_eba15ba0-81ca-4d0f-9fad-3fc1fc92c181.pdf - 80 - 143.198.231.177 Mozilla/5.0+(X11;+Linux+x86_64;+rv:128.0)+Gecko/20100101+Firefox/128.0 http://resumeupload.wowza.edu/resumes/Resume9_eba15ba0-81ca-4d0f-9fad-3fc1fc92c181.pdf 200 0 0 2081179
 11793  2025-07-27 20:10:55 192.168.189.150 GET /resumes/Resume9_eba15ba0-81ca-4d0f-9fad-3fc1fc92c181.pdf - 80 - 143.198.231.177 Mozilla/5.0+(X11;+Linux+x86_64;+rv:128.0)+Gecko/20100101+Firefox/128.0 - 200 0 0 7
 11794  2025-07-27 20:11:13 192.168.189.150 GET /resumes/Resume9_eba15ba0-81ca-4d0f-9fad-3fc1fc92c181.pdf fdir=C%3a%2finetpub%2fwwwroot%2fresumes%2f&del=C%3a%2finetpub%2fwwwroot%2fresumes%2f%2f8619.exe 80 - 143.198.231.177 Mozilla/5.0+(X11;+Linux+x86_64;+rv:128.0)+Gecko/20100101+Firefox/128.0 http://resumeupload.wowza.edu/resumes/Resume9_eba15ba0-81ca-4d0f-9fad-3fc1fc92c181.pdf 200 0 0 8
 11795  2025-07-27 20:11:23 192.168.189.150 GET /resumes/Resume9_eba15ba0-81ca-4d0f-9fad-3fc1fc92c181.pdf fdir=C%3a%2finetpub%2fwwwroot%2fresumes%2f&del=C%3a%2finetpu
```

after decode it



The URL decoded value was `C:/inetpub/wwwroot/resumes//8619.exe`, which corresponds to `C:\inetpub\wwwroot\resumes\8619.exe`. The double slash is a redundant path separator.

~Q5 Using the webshell, the threat actor uploaded a file on the endpoint to facilitate initial remote access. Identify the full path of this file.
`c:\inetpub\wwwroot\resumes\8619.exe`

~Q6 The threat actor accessed a shared folder meant for the resume reviewers. What is the full path of the first file they retrieved?
`C:\Shares\ResumeReview\Certificate_for_sign.cer`

but what the attacker see inside share folder but because the file was no longer directly available in the file tree, I analyzed the `$MFT` to locate its MFT record
"*The Master File Table (MFT) is the core file in the NTFS file system on Windows, and it has at least one entry for every file on the drive. It stores file metadata like size, timestamps, permissions, and (for small files) some data content*".

but in this case of type of file, I need to fix the file, so i use this tool

```
Name: analyzeMFT
Version: 3.1.1
Summary: Analyze the $MFT from a NTFS filesystem.
```

`analyzemft -f '$MFT' -o mft.csv`

```
└─$ analyzemft -f '$MFT' -o mft.csv
2026-09-28 09:39:09 - analyzeMFT.validators - WARNING - Large attribute detected: type=144, length=688, reco
4
2026-09-28 09:39:09 - analyzeMFT.validators - WARNING - Large attribute detected: type=144, length=600, reco
4
2026-09-28 09:39:09 - analyzeMFT.validators - WARNING - Large attribute detected: type=128, length=648, reco
4
2026-09-28 09:39:09 - analyzeMFT.validators - WARNING - Large attribute detected: type=128, length=576, reco
4
2026-09-28 09:39:09 - analyzeMFT.validators - WARNING - Large attribute detected: type=144, length=672, reco
```

so after using the tool the output still not readable i need and notice that the file `ideal candidates.txt` was identified in the `$MFT` as **MFT record 913**.

```
└─$ grep -ai "ideal candidates" mft.csv
913,Valid,In Use,File,8,1112,0,ideal candidates.txt,,2025-07-27T17:20:35.271Z,2025-07-27T17:23:52.489Z,2025-07-27T17:23
:52.489Z,2025-07-27T17:32:14.816Z,2025-07-27T17:20:35.271Z,2025-07-27T17:20:35.271Z,2025-07-27T17:20:35.271Z,2025-07-27
T17:20:35.271Z,6c20a386-69cf-11f0-8b69-000c29c70242,00000080-0060-0000-0000-180000000100,00000046-0018-0000-4c6f-6f6b69
6e6720,20726f66-6f73-656d-6f6e-65206c696b65,True,False,True,False,False,True,False,False,False,False,False,False,False,
[],None,,None,"{'name': '', 'non_resident': False, 'content_size': 70, 'start_vcn': None, 'last_vcn': None}",None,None,
None,None,None,None,None,,,,
```

The record started with the `FILE` signature, confirm that it was a valid NTFS MFT record, after MFT fixup using this script but before i need to know some info about NTFS attribute and how really make a fixup :

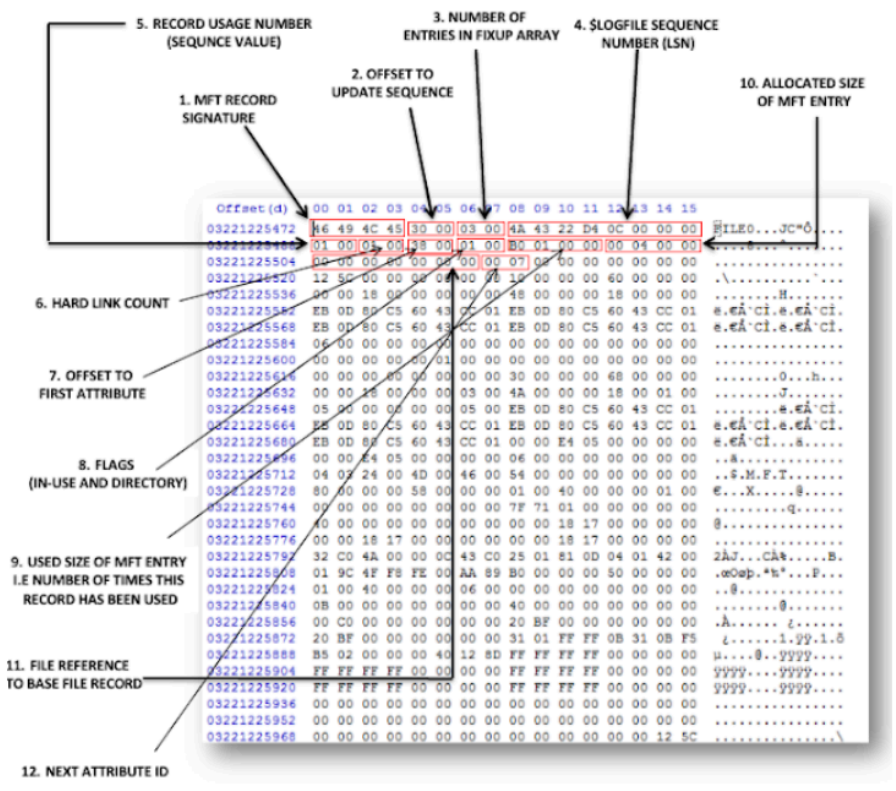
Type Code	Attribute Name	Description
0x10	StandardInformation	File timestamps, flags, owner/security IDs
0x20	AttributeList	List of attributes for fragmented records
0x30	FileName	File name, parent directory reference, timestamps
0x40	ObjectId	GUID for the file
0x50	SecurityDescriptor	Access control information
0x60	VolumeName	Volume label (root directory only)
0x70	VolumeInformation	Volume version and flags
0x80	Data	File content (unnamed stream) or ADS (named)
0x90	IndexRoot	B-tree root for directories
0xA0	IndexAllocation	B-tree nodes for large directories
0xB0	Bitmap	Allocation bitmap for indexes
0xC0	ReparsePoint	Symbolic link or mount point data
0xD0	EaInformation	Extended attribute information
0xE0	Ea	Extended attributes
0xF0	PropertySet	Property data
0x100	LoggedUtilityStream	EFS and other logged streams

sk Devin about forensicxlab/exhume_ntfs

Home > Hard Disks and File System Forensics

The NTFS Master File Table (MFT)

Joseph Moronwi March 21, 2022 0



the script:

```
import struct
#library used to read values from the raw binary record
FILE= "record_913.bin"  #MFT record need to analysis
#open the record as binary data
with open(FILE, "rb") as f:
    record= bytearray(f.read())

print(f"[~] Record size: {len(record)} bytes")
#check the record size
print(f"[~] Signature: {record[0:4].decode(errors='replace')}")

#=MFT fixup stage=

#get the location and size of the Update Sequence Array (USA)
usa_offset= struct.unpack_from("<H", record, 4)[0]
usa_count= struct.unpack_from("<H", record, 6)[0]

print(f"[~] USA offset: 0x{usa_offset:x}")
print(f"[~] USA count: {usa_count}")

#read the USA values
usa= [
    struct.unpack_from("<H", record, usa_offset + i * 2)[0]
    for i in range(usa_count)
]
sequence = usa[0]
#first value is used to check the sector endings

for i in range(1, usa_count):
#check the end of each sector and restore the original values
    sector_end= i * 512 - 2  # Last 2 bytes of the current 512-byte sector

    current= struct.unpack_from("<H", record, sector_end)[0]

#make sure the fixup value matches
    if current != sequence:
        raise ValueError(
            f"Fixup mismatch at 0x{sector_end:x}: "
            f"expected {sequence:04x}, got {current:04x}"
        )

#put the original sector value back
    struct.pack_into("<H", record, sector_end, usa[i])

print("[+] MFT fixup completed")
#=parse stage=
attr_offset= struct.unpack_from("<H", record, 0x14)[0]
#find where the first attribute starts
print(f"[+] First attribute: 0x{attr_offset:x}")

#get the NTFS attribute IDs to readable names
attribute_names= {
    0x10: "STANDARD_INFORMATION",
    0x20: "ATTRIBUTE_LIST",
    0x30: "FILE_NAME",
    0x40: "OBJECT_ID",
    0x50: "SECURITY_DESCRIPTOR",
    0x60: "VOLUME_NAME",
    0x70: "VOLUME_INFORMATION",
    0x80: "DATA",
    0x90: "INDEX_ROOT",
    0xA0: "INDEX_ALLOCATION",
    0xB0: "$BITMAP",
}

while attr_offset < len(record):
#go through the attributes one by one

    attr_type= struct.unpack_from("<I", record, attr_offset)[0]
#read the attribute type

    if attr_type== 0xFFFFFFFF:
        break
```

```
#0xFFFFFFFF this means there are no more attributes

    attr_length= struct.unpack_from("<I", record, attr_offset + 4)[0]
#get the size of the current attribute

    if attr_length== 0:
        break
#stop if the attribute looks invalid

    name= attribute_names.get(
        attr_type,
        f"UNKNOWN 0x{attr_type:x}"
    )
#get a readable name for the attribute

    non_resident= record[attr_offset + 8]
#ccheck whether the attribute is resident or not resident
    print()
    print(f"[#] Attribute: {name}")
    print(f"    Offset: 0x{attr_offset:x}")
    print(f"    Length: {attr_length}")
    print(f"    Non-resident: {bool(non_resident)}")


#resident attribute
    if non_resident== 0:

#get the size of the actual attribute data
        content_size= struct.unpack_from(
            "<I",
            record,
            attr_offset + 0x10
        )[0]

#get where the actual data starts
        content_offset= struct.unpack_from(
            "<H",
            record,
            attr_offset + 0x14
        )[0]

#get the actual position of the data
        content_start= attr_offset + content_offset
        content_end= content_start + content_size

#extract the attribute data
        data= bytes(record[content_start:content_end])

        print(f"    Content size: {content_size}")
        print(f"    Content offset: 0x{content_offset:x}")
        print(f"    Content starts: 0x{content_start:x}")


#FILE_NAME attribute
        if attr_type== 0x30:

#make sure the record is long enough to contain the filename
            if len(data) >= 0x41:

#filename length is stored at offset 0x40
                name_length= data[0x40]

#filename starts at offset 0x42 and uses UTF-16LE
                filename= data[
                    0x42:0x42 + name_length * 2
                ].decode(
                    "utf-16le",
                    errors="replace"
                )

                print(f"    Filename: {filename}")


#$DATA attribute
```

```
        elif attr_type== 0x80:
            print()
            print("========== $DATA CONTENT ==========")
#print the file content as text
            print(data.decode("utf-8", errors="replace"))
            print("====================================")

    attr_offset += attr_length
#move to the next attribute
```

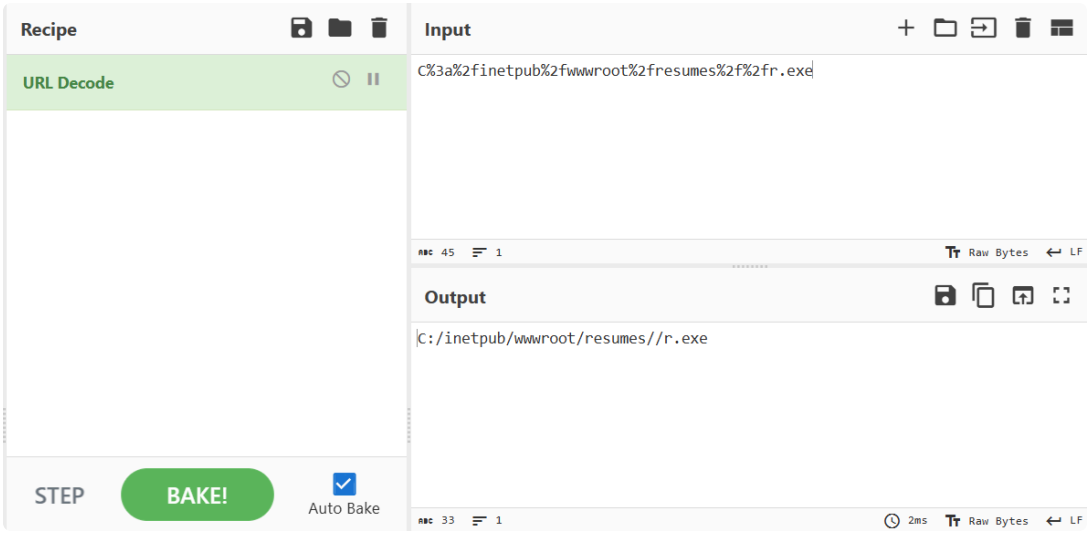
and i recovered this data:

```
========== $DATA CONTENT ==========
Looking for someone like them
- warlocksmurf
- tmechen
- lukasLUZSC
====================================
```

~Q7 Who was the first ideal candidate the company was seeking?
`warlocksmurf`

the potential attack was also showed in logs `u_ex250727.log` during the cleanup phase, the attacker used the webshell to delete a file from the `resumes` directory using the following URL encoded parameter:

```
 11799  2025-07-27 20:11:36 192.168.189.150 GET /resumes/Resume9_eba15ba0-81ca-4d0f-9fad-3fc1fc92c181.pdf fdir=C%3a%2finetpub%2fwwwroot%2fresumes%2f&del=C%3a%2finetpub%2fwwwroot%2fresumes%2f%2fr.exe 80 - 143.198.231.177 Mozilla/5.0+(X11;+Linux+x86_64;+rv:128.0)+Gecko/20100101+Firefox/128.0 http://resumeupload.wowza.edu/resumes/Resume9_eba15ba0-81ca-4d0f-9fad-3fc1fc92c181.pdf?fdir=C%3a%2finetpub%2fwwwroot%2fresumes%2f&del=C%3a%2finetpub%2fwwwroot%2fresumes%2f%2fPDFSigner.json 200 0 0 7
 11800  2025-07-27 20:11:38 192.168.189.150 GET /resumes/Resume9_eba15ba0-81ca-4d0f-9fad-3fc1fc92c181.pdf fdir=C%3a%2finetpub%2fwwwroot%2fresumes%2f&del=C%3a%2finetpub%2fwwwroot%2fresumes%2f%2fsecretsdump.exe 80 - 143.198.231.177 Mozilla/
```



so the Decoded path:
`C:/inetpub/wwwroot/resumes//r.exe`, but we need normalized it to be like Windows path:
`C:\inetpub\wwwroot\resumes\r.exe`

but what is Kerberoasting attack?
is a cyberattack that exploits the Kerberos authentication protocol, primarily used in Active Directory environments. The goal of this attack is to steal service-account credentials, allowing attackers to gain unauthorized access to network resources.

`r.exe` was identified as the dropped executable associated with the potential Kerberoasting activity, based on its filesystem activity and the subsequent creation of `roasted.txt`

Kerberoasting

Syntax:

python3 GetUserSPNs.py -request [*domain name/username*] -dc-ip [*IP address*] -outputfile [*file*]

```
python3 /opt/impacket/examples/GetUserSPNs.py
-request soupedecode.local/ybob317 -dc-ip 10.10.192.68
-outputfile Roasted.txt

cat Roasted.txt
```

The name `roasted.txt` is a very clear indicator of Kerberoasing, usually containing a service ticket for offline cracking.

~Q8 A file was dropped to perform a potential Kerberoasting attack in the Active Directory environment. What is the name of this file?
`r.exe`

and we need more details about attack, so lets dive more deep to see whats happen, the first i will go to `JobApplicant/C/Windows/System32/winevt/logs` here will found the security, AD logs

```
┌──(khaledd㉿VanTab)-[~/…/Windows/System32/winevt/logs]
└─$ ls
'Active Directory Web Services.evtx'
 Application.evtx
'DFS Replication.evtx'
'Directory Service.evtx'
'DNS Server.evtx'
 Microsoft-Client-Licensing-Platform%4Admin.evtx
 Microsoft-Windows-AAD%4Operational.evtx
 Microsoft-Windows-Application-Experience%4Program-Telemetry.evtx
 Microsoft-Windows-AppModel-Runtime%4Admin.evtx
 Microsoft-Windows-AppReadiness%4Admin.evtx
 Microsoft-Windows-AppReadiness%4Operational.evtx
 Microsoft-Windows-AppXDeployment%4Operational.evtx
 Microsoft-Windows-AppXDeploymentServer%4Operational.evtx
 Microsoft-Windows-AppxPackaging%4Operational.evtx
 Microsoft-Windows-BackgroundTaskInfrastructure%4Operational.evtx
 Microsoft-Windows-Biometrics%4Operational.evtx
 Microsoft-Windows-Bits-Client%4Operational.evtx
 Microsoft-Windows-CertificateServicesClient-Lifecycle-System%4Operational.evtx
 Microsoft-Windows-CertificateServices-Deployment%4Operational.evtx
 Microsoft-Windows-CloudStore%4Operational.evtx
 Microsoft-Windows-CodeIntegrity%4Operational.evtx
 Microsoft-Windows-Containers-BindFlt%4Operational.evtx
 Microsoft-Windows-Containers-Wcifs%4Operational.evtx
 Microsoft-Windows-Crypto-DPAPI%4BackUpKeySvc.evtx
 Microsoft-Windows-WinINet%4Operational.evtx
 Microsoft-Windows-WinINet-Config%4ProxyConfigChanged.evtx
 Microsoft-Windows-Winlogon%4Operational.evtx
 Microsoft-Windows-WinRM%4Operational.evtx
 Microsoft-Windows-Winsock-WS2HELP%4Operational.evtx
 Microsoft-Windows-Wired-AutoConfig%4Operational.evtx
 Microsoft-Windows-WMI-Activity%4Operational.evtx
 Microsoft-Windows-WMPNSS-Service%4Operational.evtx
'Microsoft-Windows-Workplace Join%4Admin.evtx'
 Microsoft-Windows-WPD-ClassInstaller%4Operational.evtx
 Microsoft-Windows-WPD-CompositeClassDriver%4Operational.evtx
 Microsoft-Windows-WPD-MTPClassDriver%4Operational.evtx
 OpenSSH%4Operational.evtx
 Security.evtx
 Setup.evtx
 System.evtx
'Windows PowerShell.evtx'
```

and to see which AD account was targeted, we moved to the Windows `Security.evtx` and search for Kerberos Service Ticket events, event 4769.

4769: A Kerberos service ticket was requested

On this page

- Description of this event
- Field level details
- Examples

Windows uses this event ID for both successful and failed service ticket requests. If it is a failure event see Failure Code: below.

Whereas event ID 4768 lets you track initial logons through the granting of TGTs, this lets you monitor the granting of service tickets.

Service tickets are obtained whenever a user or computer accesses a server on the network. For example, when a user maps a drive to a file server, the resulting service ticket request generates event ID 4769 on the DC.

Operating Systems	Windows 2008 R2 and 7 Windows 2012 R2 and 8.1 Windows 2016 and 10 Windows Server 2019 and 2022 Windows Server 2025
Category • Subcategory	Account Logon • Kerberos Service Ticket Operations
Type	Success Failure
Corresponding events in Windows 2003 and before	673

but i cant read this type of files `evtx "Windows Event Log file"` so i just use this tool `evtxexport` the will convert it to txt can read.

NAME

evtxexport – exports items stored in a Windows XML EventViewer Log (EVTX) file

SYNOPSIS

evtxexport [**-c** *codepage*] [**-f** *format*] [**-l** *log_file*] [**-m** *mode*] [**-p** *message_files_path*] [**-r** *registy_files_path*] [**-s** *system_file*] [**-S** *software_file*] [**-t** *event_log_type*] [**-hTvV**] *source*

DESCRIPTION

evtxexport is a utility to export items stored in a Windows XML EventViewer Log (EVTX) file

evtxexport is part of the **libevtx** package. **libevtx** is a library to access the Windows XML EventViewer Log (EVTX) file

source is the source file.

```
└─$ evtxexport -h
evtxexport 20251118

Use evtxexport to export items stored in a Windows XML Event Viewer
Log (EVTX) file.

Usage: evtxexport [ -c codepage ] [ -f format ] [ -l log_file ]
                  [ -m mode ] [ -p resource_files_path ]
                  [ -r registy_files_path ] [ -s system_file ]
                  [ -S software_file ] [ -t event_log_type ]
                  [ -hTvV ] source

        source: the source file

        -c:     codepage of ASCII strings, options: ascii, windows-874,
                windows-932, windows-936, windows-949, windows-950,
                windows-1250, windows-1251, windows-1252 (default),
                windows-1253, windows-1254, windows-1255, windows-1256
                windows-1257 or windows-1258
        -f:     output format, options: xml, text (default)
        -h:     shows this help
        -l:     logs information about the exported items
        -m:     export mode, option: all, items (default), recovered
                'all' exports the (allocated) items and recovered items,
                'items' exports the (allocated) items and 'recovered' exports
                the recovered items
        -p:     search PATH for the resource files
        -r:     name of the directory containing the SOFTWARE and SYSTEM
                (Windows) Registry file
        -s:     filename of the SYSTEM (Windows) Registry file.
                This option overrides the path provided by -r
```

now can search to found the target event

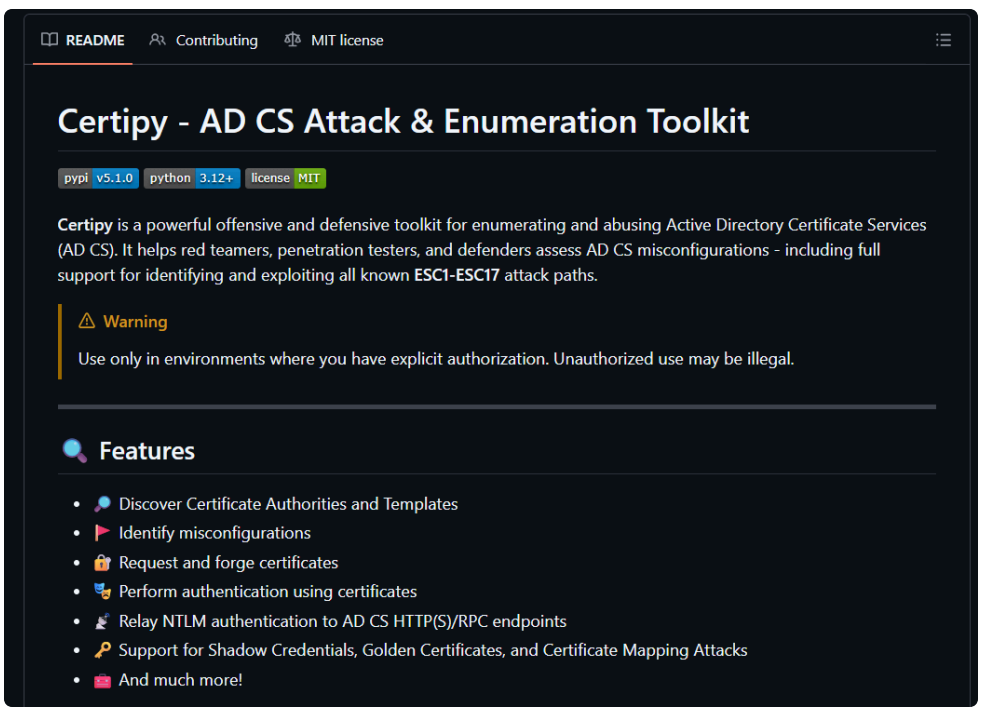
```
Event number                     : 26457
Creation time                    : Jul 27, 2025 19:40:39.896107900 UTC
Written time                     : Jul 27, 2025 19:40:39.896107900 UTC
Event version                    : 0
Event level                      : Information (0)
Computer name                    : MAIN-DC.wowza.edu
Source name                      : Microsoft-Windows-Security-Auditing
Channel name                     : Security
Event identifier                 : 0x000012a1 (4769)
Number of strings                : 11
String: 1                        : iis_svc@WOWZA.EDU
String: 2                        : WOWZA.EDU
String: 3                        : ca_svc
String: 4                        : S-1-5-21-2525499130-77348690-3507557611-1106
String: 5                        : 0x40800000
String: 6                        : 0x00000017
String: 7                        : ::1
String: 8                        : 0
String: 9                        : 0x00000000
String: 10                       : {B287DB3E-1DB1-8457-7046-C433A7E9AEEB}
String: 11                       : -
```

One event showed `iis_svc@WOWZA.EDU` requesting a service ticket for `ca_svc`. The ticket used encryption type `0x17` (RC4-HMAC), which is relevant to Kerberoasting investigations. the service account targeted in this Active Directory attack was `WOWZA.edu\ca_svc`.

~Q9 Which service account was targeted by this active directory attack?
`WOWZA.edu\ca_svc`

also on the `u_ex250727.log` found that attacker use a famous tool and he try to delete it using `del` parameter

```
mes%2f&del=C%3a%2finetpub%2fwwwroot%2fresumes%2f%2fadministrator.ccache 200 0 0 8
 11797  2025-07-27 20:11:31 192.168.189.150 GET /resumes/Resume9_eba15ba0-81ca-4d0f-9fad-3fc1fc92c181.pdf fdir=C%3a%2finetpub%2fwwwroot%2fresu
mes%2f&del=C%3a%2finetpub%2fwwwroot%2fresumes%2f%2fCertipy.exe 80 - 143.198.231.177 Mozilla/5.0+(X11;+Linux+x86_64;+rv:128.0)+Gecko/20100101+F
irefox/128.0 http://resumeupload.wowza.edu/resumes/Resume9_eba15ba0-81ca-4d0f-9fad-3fc1fc92c181.pdf?fdir=C%3a%2finetpub%2fwwwroot%2fresumes%2f
```



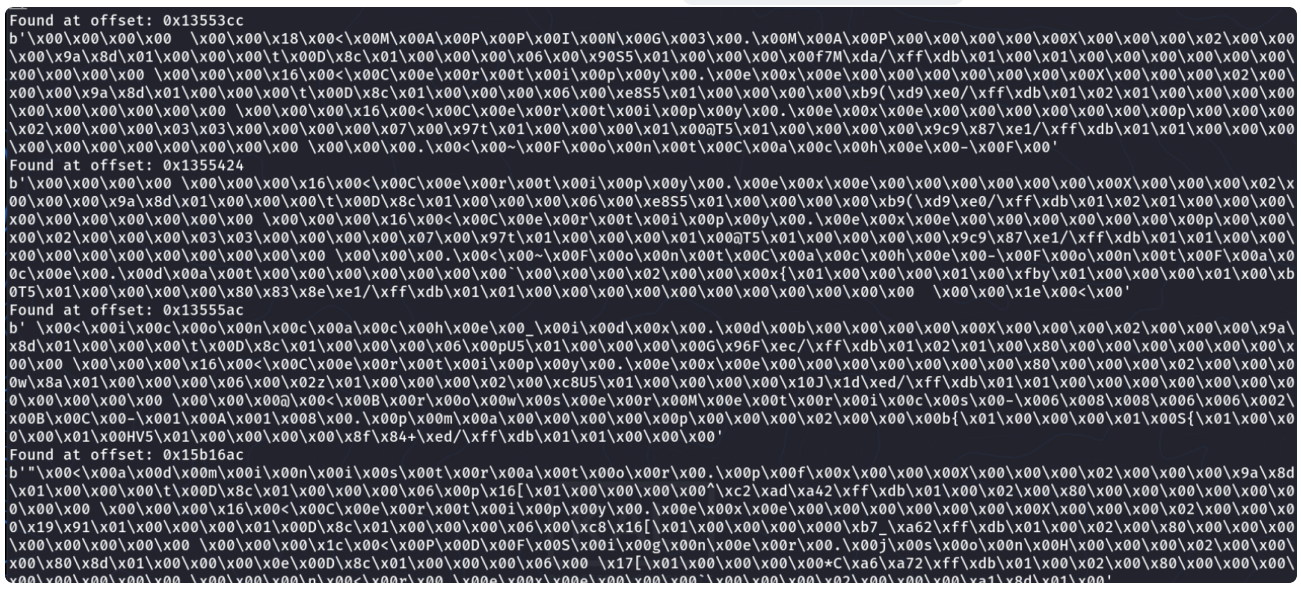
and to know when the time that tool was create and run also we need to look up on `$MFT` that already converted to csv file so can see what inside

```
┌──(mft-env)─(khaledd㉿VanTab)-[~/HTB/dFIR/JobApplicant/C]
└─$ strings ~/HTB/dFIR/JobApplicant/C/'$MFT' | grep -i "Certipy.exe"

┌──(mft-env)─(khaledd㉿VanTab)-[~/HTB/dFIR/JobApplicant/C]
└─$ grep -a -i "Certipy.exe" ~/HTB/dFIR/JobApplicant/C/'$MFT'
```

but its don't count this event

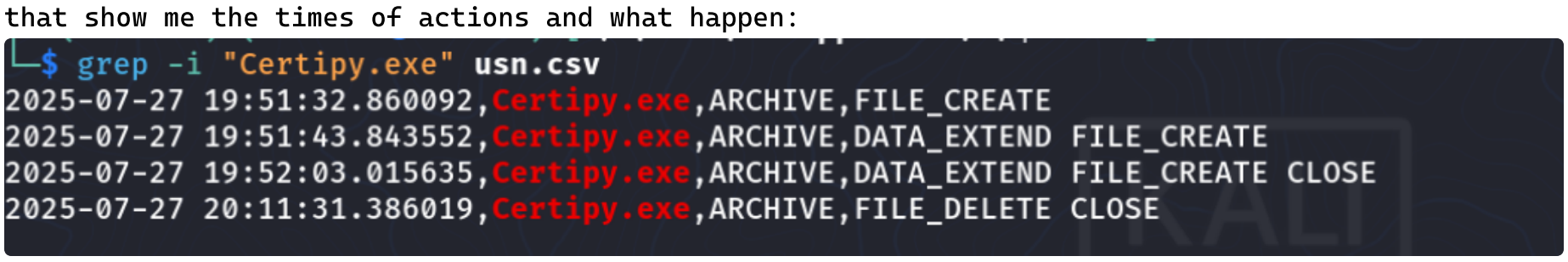
so lets see the another on one like `$J "USN Journal"` so i found this



but its not readable so i download and use `usn.py` tool:



that show me the times of actions and what happen:



`2025-07-27 19:51:32.860092,Certipy.exe,ARCHIVE,FILE_CREATE`
The file was created.

`2025-07-27 19:51:43.843552,Certipy.exe,ARCHIVE,DATA_EXTEND FILE_CREATE`
The file was created and data was added to it.

`2025-07-27 19:52:03.015635,Certipy.exe,ARCHIVE,DATA_EXTEND FILE_CREATE CLOSE`
The file was created, data was added to it, and the file was closed.

`2025-07-27 20:11:31.386019,Certipy.exe,ARCHIVE,FILE_DELETE CLOSE`
The file was deleted and then closed.

~Q10 Attacker dropped another tool to exploit a misconfiguration in AD CS. When was this tool successfully created on the endpoint?
`2025-07-27 19:52:03`

and we need to know when that exploit happen on the domain controller and one of above logs will help us to see this event `Security.evtx`, and already i have readable copy of it!

the interest event we need to see it about exploit is event 4886 "*Certificate Services received a certificate request*" and this also event 4887 "*Certificate Services approved a certificate*

request and issued a certificate"

4886: Certificate Services received a certificate request

On this page

- Description of this event
- Field level details
- Examples

Operating Systems	Windows 2008 R2 and 7 Windows 2012 R2 and 8.1 Windows 2016 and 10 Windows Server 2019 and 2022 Windows Server 2025
Category • Subcategory	Object Access • Certification Services
Type	Success
Corresponding events in Windows 2003 and before	

When the Certification Authority receives a certificate reqeuest it logs this event.

Then it evaluates the request, loading the relavent certificate template if appropriate (event 4898). Then the CA will place the request into the Pending Requests folder (4889), immediately issue (4887) or deny it (4888).

This event event is only logged if "Issue and manage certificate requests" is enabled on the Audit tab of the CA's properties in Certificate Services MMC snap-in and of course if the Certificate Services audit subcategory is enabled with auditpol.

4887: Certificate Services approved a certificate request and issued a certificate

On this page

- Description of this event
- Field level details
- Examples

Operating Systems	Windows 2008 R2 and 7 Windows 2012 R2 and 8.1 Windows 2016 and 10 Windows Server 2019 and 2022 Windows Server 2025
Category • Subcategory	Object Access • Certification Services
Type	Success
Corresponding events in Windows 2003 and before	

This event is logged when a certificate is issued as a result of either:

- An administrator or certificate manager issues a pending request
- The CA automatically approves the request based on the CA's policy and that of the certificate template associated with the request.

lets see:

```
Event number                     : 26688
Creation time                    : Jul 27, 2025 19:56:38.095869900 UTC
Written time                     : Jul 27, 2025 19:56:38.095869900 UTC
Event version                    : 0
Event level                      : Information (0)
Computer name                    : MAIN-DC.wowza.edu
Source name                      : Microsoft-Windows-Security-Auditing
Channel name                     : Security
Event identifier                 : 0x00001316 (4886)
Number of strings                : 3
String: 1                        : 6
String: 2                        : WOWZA\ca_svc
String: 3                        : CertificateTemplate:PDFSigner
SAN:upn=Administrator
```

```
Event number                     : 26770
Creation time                    : Jul 27, 2025 19:56:49.492937700 UTC
Written time                     : Jul 27, 2025 19:56:49.492937700 UTC
Event version                    : 0
Event level                      : Information (0)
Computer name                    : MAIN-DC.wowza.edu
Source name                      : Microsoft-Windows-Security-Auditing
Channel name                     : Security
Event identifier                 : 0x00001317 (4887)
Number of strings                : 6
String: 1                        : 6
String: 2                        : WOWZA\ca_svc
String: 3                        : CertificateTemplate:PDFSigner
SAN:upn=Administrator
String: 4                        : 3
String: 5                        : d2 5d 70 89 4b 74 b9 6c ae f7 7c c0 f8 a3 ac 74 6d 2f a2 6b
String: 6                        : CN=Ca_svc
```

so now we have the time of the exploit!
and `SAN:upn=Administrator` that prove that the attacker abuse the misconfiguration of the AD CS template to get a certificate as a Administrator.

~Q11 When was AD CS exploited successfully on the domain controller?
`2025-07-27 19:56:38`

and the version of certificate "PDFSigner templete" is 100.4.

```
      : Jul 27, 2025 19:56:38.185611200 UTC
      : 0x00001324 (4900)
      : PDFSigner
      : 100.4
      : 1.3.6.1.4.1.311.21.8.9275752.14118362.13453185.9255442.11021361.47.8099548.5712546
      : CN=PDFSigner,CN=Certificate Templates,CN=Public Key Services,CN=Services,CN=Configuration,DC=wowza,DC=edu
      : Jul 27, 2025 19:56:38.188533100 UTC
      : 0x00001322 (4898)
      : PDFSigner
      : 100.4
      : 1.3.6.1.4.1.311.21.8.9275752.14118362.13453185.9255442.11021361.47.8099548.5712546
      : CN=PDFSigner,CN=Certificate Templates,CN=Public Key Services,CN=Services,CN=Configuration,DC=wowza,DC=edu
sion = 2
```

~Q12 Identify the name and version of the vulnerable certificate template exploited in the attack.

`PDFSigner v100.4`

if we want to see what the type of access that gain after get the certificate also i need to see the `Security.evtx` and follow what happen.

```
└─$ grep -in -B 20 -A 40 'PDFSigner' security-export.txt | grep -iE 'security descriptor|Full Control|FULL_CONTROL|GenericAll|Gro
'
255946- Full Control
255948- Full Control
324984- Full Control
324986- Full Control
425014- Full Control
425016- Full Control
429769- Full Control
429771- Full Control
454405- Full Control
454407- Full Control
495668- Full Control
495715- Full Control
495717- Full Control
495719- Full Control
495813- Full Control
498154-String: 8                       : Object Access
```

and after expand this log i found interest part that the PDFSigner template security descriptor grants Full Control

```
String: 8                       : O:LAG:S-1-5-21-2525499130-77348690-3507557611-519D:PAI(A;;CCDCLCSWRPWPDTLOCRSDRCWDWO;;;AU)

Allow(0x000f01ff)       NT AUTHORITY\Authenticated Users
        Full Control
```

~Q13 A new security descriptor was applied to the vulnerable certificate template and this security descriptor grants full control over the certificate template to a specific group. What is the name of that group?

`Authenticated Users`

and to determine when the certificate was issued to the threat actor for a high privilege account, I analyst `Security.evtx` for event 4887 but now with `Administrator` flag.

```
498103-Event number                     : 26793
498104-Creation time                    : Jul 27, 2025 19:57:55.676311100 UTC
498105-Written time                     : Jul 27, 2025 19:57:55.676311100 UTC
498106-Event version                    : 0
498107-Event level                      : Information (0)
498108-Computer name                    : MAIN-DC.wowza.edu
498109-Source name                      : Microsoft-Windows-Security-Auditing
498110-Channel name                     : Security
498111-Event identifier         : 0x00001317 (4887)
498112-Number of strings                : 6
498113-String: 1                        : 8
498114-String: 2                        : WOWZA\ca_svc
498115-String: 3                        : CertificateTemplate:PDFSigner
498116:SAN:upn=Administrator
```

~Q14 When was the certificate issued to the threat actor for a high-privilege user, allowing privilege escalation?

`2025-07-27 19:57:55`

to find the serial number of the certificate used for privilege escalation also i need to analyst the `Security.evtx` and spicaily for event 4768 "*A Kerberos authentication ticket was requested*" that will show the moment of when the attacker kerbores TGT for the privileged account.

```
Event number                     : 26803
Creation time                    : Jul 27, 2025 19:59:15.187294600 UTC
Written time                     : Jul 27, 2025 19:59:15.187294600 UTC
Event version                    : 0
Event level                      : Information (0)
Computer name                    : MAIN-DC.wowza.edu
Source name                      : Microsoft-Windows-Security-Auditing
Channel name                     : Security
Event identifier                 : 0x000012a0 (4768)
Number of strings                : 14
String: 1                        : Administrator
String: 2                        : WOWZA.EDU
String: 3                        : S-1-5-21-2525499130-77348690-3507557611-500
String: 4                        : krbtgt
String: 5                        : S-1-5-21-2525499130-77348690-3507557611-502
String: 6                        : 0x40800010
String: 7                        : 0x00000000
String: 8                        : 0x00000012
String: 9                        : 16
String: 10                       : ::ffff:127.0.0.1
String: 11                       : 57899
String: 12                       : wowza-MAIN-DC-CA
String: 13                       : 1D00000008A6E7524F029E603A000000000008
```

~Q15 The threat actor successfully retrieved the NTLM hash of a high-privilege user using the newly issued certificate. What was the serial number of the certificate used to achieve this privilege escalation?v

`1D00000008A6E7524F029E603A000000000008`

in this point of investigation, the evidence showed that the attacker had successfully abused the vulnerable `PDFSigner` certificate template to obtain a certificate for the high privilege `Administrator` account.

```
Event number                     : 26871
Creation time                    : Jul 27, 2025 20:05:14.708473300 UTC
Written time                     : Jul 27, 2025 20:05:14.708473300 UTC
Event version                    : 0
Event level                      : Information (0)
Computer name                    : MAIN-DC.wowza.edu
Source name                      : Microsoft-Windows-Security-Auditing
Channel name                     : Security
Event identifier                 : 0x00001236 (4662)
Number of strings                : 14
String: 1                        : S-1-5-21-2525499130-77348690-3507557611-500
String: 2                        : Administrator
String: 3                        : WOWZA
String: 4                        : 0x000000000096a4b9
String: 5                        : DS
String: 6                        : %{19195a5b-6da0-11d0-afd3-00c04fd930c9}
String: 7                        : %{79b0ad16-fa24-4c38-9ee3-99b23dcf997f}
String: 8                        : Object Access
String: 9                        : 0x0000000000000000
String: 10                       : %%7688

String: 11                       : 0x00000100
String: 12                       : %%7688
                {1131f6aa-9c07-11d1-f79f-00c04fc2dcd2}
        {19195a5b-6da0-11d0-afd3-00c04fd930c9}
```

```
Event number                     : 26872
Creation time                    : Jul 27, 2025 20:05:14.708606200 UTC
Written time                     : Jul 27, 2025 20:05:14.708606200 UTC
Event version                    : 0
Event level                      : Information (0)
Computer name                    : MAIN-DC.wowza.edu
Source name                      : Microsoft-Windows-Security-Auditing
Channel name                     : Security
Event identifier                 : 0x00001236 (4662)
Number of strings                : 14
String: 1                        : S-1-5-21-2525499130-77348690-3507557611-500
String: 2                        : Administrator
String: 3                        : WOWZA
String: 4                        : 0x000000000096a4b9
String: 5                        : DS
String: 6                        : %{19195a5b-6da0-11d0-afd3-00c04fd930c9}
String: 7                        : %{79b0ad16-fa24-4c38-9ee3-99b23dcf997f}
String: 8                        : Object Access
String: 9                        : 0x0000000000000000
String: 10                       : %%7688

String: 11                       : 0x00000100
String: 12                       : %%7688
                {1131f6ad-9c07-11d1-f79f-00c04fc2dcd2}
        {19195a5b-6da0-11d0-afd3-00c04fd930c9}
```

So this GUIDs for the following Active Directory replication permissions:

6.1.1.2.7.66 DS-Replication-Get-Changes

Summarize this article for me

This object is present in AD DS and AD LDS.

name: DS-Replication-Get-Changes

rightsGuid: 1131f6aa-9c07-11d1-f79f-00c04fc2dcd2

6.1.1.2.7.38 DS-Replication-Get-Changes-All

Summarize this article for me

This object is present in AD DS and AD LDS.

name: DS-Replication-Get-Changes-All

rightsGuid: 1131f6ad-9c07-11d1-f79f-00c04fc2dcd2

The presence of this replication permissions in our case of the attack is consistent with **DCSync**, where an attacker abuse AD replication functionality to request credential related data from a Domain Controller.

This technique is guide us to the MITRE ATT&CK technique:

T1003.006 — OS Credential Dumping

OS Credential Dumping: DCSync

Other sub-techniques of OS Credential Dumping (8)

Adversaries may attempt to access credentials and other sensitive information by abusing a Windows Domain Controller's application programming interface (API)[1] [2] [3] [4] to simulate the replication process from a remote domain controller using a technique called DCSync.

Members of the Administrators, Domain Admins, and Enterprise Admin groups or computer accounts on the domain controller are able to run DCSync to pull password data[5] from Active Directory, which may include current and historical hashes of potentially useful accounts such as KRBTGT and Administrators. The hashes can then in turn be used to create a Golden Ticket for use in Pass the Ticket[6] or change an account's password as noted in Account Manipulation.[7]

DCSync functionality has been included in the "lsadump" module in Mimikatz.[8] Lsadump also includes NetSync, which performs DCSync over a legacy replication protocol.[9]

ID: T1003.006
Sub-technique of: T1003
Tactic: Credential Access
Platforms: Windows
Contributors: ExtraHop; Vincent Le Toux
Version: 1.1
Created: 11 February 2020
Last Modified: 24 October 2025

Version Permalink

so after get privileged certificate based access, the attacker leveraged Active Directory replication privileges to access domain credential secrets.

~Q16 The attacker exploited an Active Directory misconfiguration to gain access to Active Directory secrets stored on the domain controller. What is the MITRE ATT&CK ID for this technique?

`T1003.006`

and when we need to see when the attack happen see this like above

```
Event number                     : 26871
Creation time                    : Jul 27, 2025 20:05:14.708473300 UTC
Written time                     : Jul 27, 2025 20:05:14.708473300 UTC
Event version                    : 0
Event level                      : Information (0)
Computer name                    : MAIN-DC.wowza.edu
Source name                      : Microsoft-Windows-Security-Auditing
Channel name                     : Security
Event identifier                 : 0x00001236 (4662)
Number of strings                : 14
String: 1                        : S-1-5-21-2525499130-77348690-3507557611-500
String: 2                        : Administrator
String: 3                        : WOWZA
String: 4                        : 0x000000000096a4b9
String: 5                        : DS
String: 6                        : %{19195a5b-6da0-11d0-afd3-00c04fd930c9}
String: 7                        : %{79b0ad16-fa24-4c38-9ee3-99b23dcf997f}
String: 8                        : Object Access
String: 9                        : 0x0000000000000000
String: 10                       : %%7688

String: 11                       : 0x00000100
String: 12                       : %%7688
                {1131f6aa-9c07-11d1-f79f-00c04fc2dcd2}
        {19195a5b-6da0-11d0-afd3-00c04fd930c9}
```

~Q17 When was the attack mentioned in the previous task successfully carried out?

`2025-07-27 20:05:14`

so back to the `u_ex250727.log` I found this file with straight extension "Kirbi" !? in the context of del parameter also.

WHAT is the Kirbi file...

Answer

Improve the Answer

A Kirbi file is a specific type of file associated with Kerberos authentication, typically seen in the context of cybersecurity incidents. Here are some key insights about Kirbi files:

1. **Kerberos Authentication**:

- Kerberos is a network authentication protocol used to verify the identity of users and services in a secure manner, primarily within Microsoft Active Directory environments [6].

2. **Kirbi File Creation**:

- Kirbi files are created when Kerberos tickets are dumped from the memory of a system. These files can be created by utilities like Mimikatz, which is an open-source tool often used for post-exploitation activities in cybersecurity attacks [2].

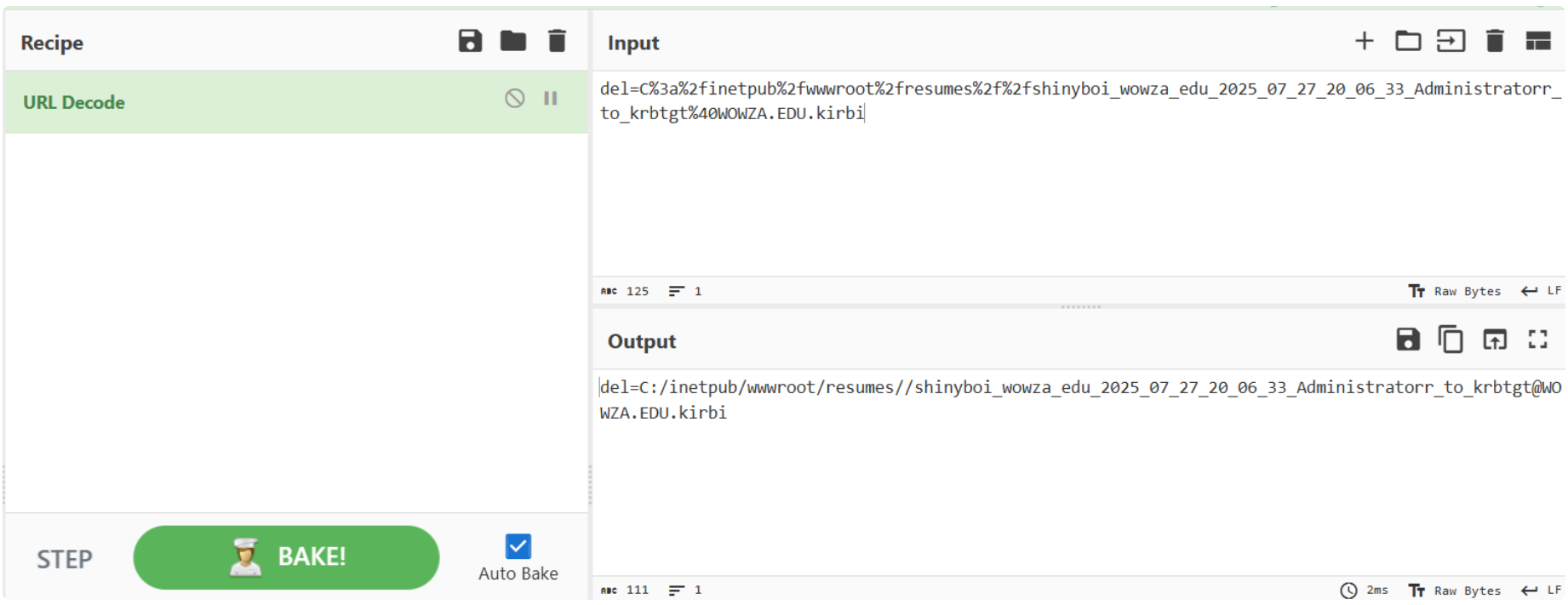
3. **Security Implications**:

- The creation of Kirbi files is a strong indicator of an attacker attempting to perform a "Pass the Ticket" attack. This type of attack involves leveraging stolen Kerberos Ticket Granting Tickets (TGTs) to gain unauthorized access to network resources [5].

- These files can contain sensitive information such as NTLM hashes, which can be cracked offline to further compromise security [8].

and now we are know what the file attacker used as a ticket.

```
 11801  2025-07-27 20:11:41 192.168.189.150 GET /resumes/Resume9_eba15ba0-81ca-4d0f-9fad-3fc1fc92c181.pdf fdir=C%3a%2finetpub%2fwwwroot%2fresumes%2f&del=C%3a%2finetpub%2fwwwroot%2fresumes%2f%2fshinyboi_wowza_edu_2025_07_27_20_06_33_Administratorr_to_krbtgt%40WOWZA.EDU.kirbi 80 - 143.198.231.177 Mozilla/5.0+(X11;+Linux+x86_64;+rv:128.0)+Gecko/20100101+Firefox/128.0 http://resumeupload.wowza.edu/resumes/Resume9_eba15ba0-81ca-4d0f-9fad-3fc1fc92c181.pdf?fdir=C%3a%2finetpub%2fwwwroot%2fresumes%2f&del=C%3a%2finetpub%2fwwwroot%2fresumes%2f%2fsecretsdump.exe 200 0 0 5
```



~Q18 A Golden Ticket was issued using a previously dropped tool. What is the filename of this ticket?

`shinyboi_wowza_edu_2025_07_27_20_06_33_Administratorr_to_krbtgt@WOWZA.EDU.kirbi`

all of this deletion and cleaning event is started from the attacker side at `11794 2025-07-27 20:11:13 192.168.189.150` after upload the pdf file.

```
 11793  2025-07-27 20:10:55 192.168.189.150 GET /resumes/Resume9_eba15ba0-81ca-4d0f-9fad-3fc1fc92c181.pdf - 80 - 143.198.231.177 Mozilla/5.0+(X11;+Linux+x86_64;+rv:128.0)+Gecko/20100101+Firefox/128.0 - 200 0 0 7
 11794  2025-07-27 20:11:13 192.168.189.150 GET /resumes/Resume9_eba15ba0-81ca-4d0f-9fad-3fc1fc92c181.pdf fdir=C%3a%2finetpub%2fwwwroot%2fresumes%2f&del=C%3a%2finetpub%2fwwwroot%2fresumes%2f%2f8619.exe 80 - 143.198.231.177 Mozilla/5.0+(X11;+Linux+x86_64;+rv:128.0)+Gecko/20100101+Firefox/128.0 http://resumeupload.wowza.edu/resumes/Resume9_eba15ba0-81ca-4d0f-9fad-3fc1fc92c181.pdf 200 0 0 8
 11795  2025-07-27 20:11:23 192.168.189.150 GET /resumes/Resume9_eba15ba0-81ca-4d0f-9fad-3fc1fc92c181.pdf fdir=C%3a%2finetpub%2fwwwroot%2fresumes%2f&del=C%3a%2finetpub%2fwwwroot%2fresumes%2f%2fadministrator.ccache 80 - 143.198.231.177 Mozilla/5.0+(X11;+Linux+x86_64;+rv:128.0)+Gecko/20100101+Firefox/128.0 http://resumeupload.wowza.edu/resumes/Resume9_eba15ba0-81ca-4d0f-9fad-3fc1fc92c181.pdf?fdir=C%3a%2finetpub%2fwwwroot%2fresumes%2f&del=C%3a%2finetpub%2fwwwroot%2fresumes%2f%2f8619.exe 200 0 0 6
 11796  2025-07-27 20:11:26 192.168.189.150 GET /resumes/Resume9_eba15ba0-81ca-4d0f-9fad-3fc1fc92c181.pdf fdir=C%3a%2finetpub%2fwwwroot%2fresumes%2f&del=C%3a%2finetpub%2fwwwroot%2fresumes%2f%2fadministrator.pfx 80 - 143.198.231.177 Mozilla/5.0+(X11;+Linux+x86_64;+rv:128.0)+Gecko/20100101+Firefox/128.0 http://resumeupload.wowza.edu/resumes/Resume9_eba15ba0-81ca-4d0f-9fad-3fc1fc92c181.pdf?fdir=C%3a%2finetpub%2fwwwroot%2fresumes%2f&del=C%3a%2finetpub%2fwwwroot%2fresumes%2f%2fadministrator.ccache 200 0 0 8
 11797  2025-07-27 20:11:31 192.168.189.150 GET /resumes/Resume9_eba15ba0-81ca-4d0f-9fad-3fc1fc92c181.pdf fdir=C%3a%2finetpub%2fwwwroot%2fresumes%2f&del=C%3a%2finetpub%2fwwwroot%2fresumes%2f%2fCertipy.exe 80 - 143.198.231.177 Mozilla/5.0+(X11;+Linux+x86_64;+rv:128.0)+Gecko/20100101+Firefox/128.0 http://resumeupload.wowza.edu/resumes/Resume9_eba15ba0-81ca-4d0f-9fad-3fc1fc92c181.pdf?fdir=C%3a%2finetpub%2fwwwroot%2fresumes%2f&del=C%3a%2finetpub%2fwwwroot%2fresumes%2f%2fadministrator.pfx 200 0 0 13
 11798  2025-07-27 20:11:34 192.168.189.150 GET /resumes/Resume9_eba15ba0-81ca-4d0f-9fad-3fc1fc92c181.pdf fdir=C%3a%2finetpub%2fwwwroot%2fresumes%2f&del=C%3a%2finetpub%2fwwwroot%2fresumes%2f%2fPDFSigner.json 80 - 143.198.231.177 Mozilla/5.0+(X11;+Linux+x86_64;+rv:128.0)+Gecko/20100101+Firefox/128.0 http://resumeupload.wowza.edu/resumes/Resume9_eba15ba0-81ca-4d0f-9fad-3fc1fc92c181.pdf?fdir=C%3a%2finetpub%2fwwwroot%2fresumes%2f&del=C%3a%2finetpub%2fwwwroot%2fresumes%2f%2fCertipy.exe 200 0 0 6
 11799  2025-07-27 20:11:36 192.168.189.150 GET /resumes/Resume9_eba15ba0-81ca-4d0f-9fad-3fc1fc92c181.pdf fdir=C%3a%2finetpub%2fwwwroot%2fresumes%2f&del=C%3a%2finetpub%2fwwwroot%2fresumes%2f%2fr.exe 80 - 143.198.231.177 Mozilla/5.0+(X11;+Linux+x86_64;+rv:128.0)+Gecko/20100101+Firefox/128.0 http://resumeupload.wowza.edu/resumes/Resume9_eba15ba0-81ca-4d0f-9fad-3fc1fc92c181.pdf?fdir=C%3a%2finetpub%2fwwwroot%2fresumes%2f&del=C%3a%2finetpub%2fwwwroot%2fresumes%2f%2fPDFSigner.json 200 0 0 7
 11800  2025-07-27 20:11:38 192.168.189.150 GET /resumes/Resume9_eba15ba0-81ca-4d0f-9fad-3fc1fc92c181.pdf fdir=C%3a%2finetpub%2fwwwroot%2fresumes%2f&del=C%3a%2finetpub%2fwwwroot%2fresumes%2f%2fsecretsdump.exe 80 - 143.198.231.177 Mozilla/5.0+(X11;+Linux+x86_64;+rv:128.0)+Gecko/20100101+Firefox/128.0 http://resumeupload.wowza.edu/resumes/Resume9_eba15ba0-81ca-4d0f-9fad-3fc1fc92c181.pdf?fdir=C%3a%2finetpub%2fwwwroot%2fresumes%2f&del=C%3a%2finetpub%2fwwwroot%2fresumes%2f%2fr.exe 200 0 0 9
 11801  2025-07-27 20:11:41 192.168.189.150 GET /resumes/Resume9_eba15ba0-81ca-4d0f-9fad-3fc1fc92c181.pdf fdir=C%3a%2finetpub%2fwwwroot%2fresumes%2f&del=C%3a%2finetpub%2fwwwroot%2fresumes%2f%2fshinyboi_wowza_edu_2025_07_27_20_06_33_Administratorr_to_krbtgt%40WOWZA.EDU.kirbi 80 - 143.198.231.177 Mozilla/5.0+(X11;+Linux+x86_64;+rv:128.0)+Gecko/20100101+Firefox/128.0 http://resumeupload.wowza.edu/resumes/Resume9_eba15ba0-81ca
```

~Q19 The threat actor used the web shell to delete all files involved in this operation. When did the deletion routine begin?

`2025-07-27 20:11:13`

THANKS

Khaled_AlKailani

2992026